CHANGE MANAGEMENT PROCESS

SOP-007 | Standard Operating Procedure | Issued under POL-007

Document ID: SOP-007
Version: 1.0 — DRAFT
Parent Policy: POL-007 — Change Management Policy
Classification: Internal Use
Owner: Information Security
Co-Owner: Data Custodian (IT)
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Change Management Process
Document ID	SOP-007
Version	1.0 — DRAFT
Parent Policy	POL-007 — Change Management Policy
Related Documents	POL-005 (System Classification), POL-006 (CSV), POL-008 (Access Control), POL-009 (PAM), POL-010 (IS Risk), POL-011 (Business Continuity), POL-012 (Incident Response), POL-014 (Audit Trail), POL-015 (IT Service Management), SOP-006 (Validation Process), SOP-008 (Access Control Process), SOP-010 (IS Risk Process), SOP-012 (Incident Response Process), SOP-015 (ITSM Process), EXC-001 (Exception Management)
Owner	Information Security Manager
Co-Owner	Data Custodian (IT)
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

NOTE: SOP-007 is the process referenced by more IMF documents than any other SOP. Whenever a policy or SOP specifies that a change must go through change management, it means this process. The change categories, approval thresholds, CAB structure, GxP impact assessment, and Emergency Change procedure defined here are the canonical definitions used throughout the IMF suite.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This SOP defines the end-to-end process for managing all changes to [Company Name]'s IT systems, infrastructure, and services. It ensures changes are planned, assessed, approved, implemented, and reviewed in a controlled manner — minimising the risk of unplanned service disruption and maintaining the integrity of GxP validated states, SOX ITGC controls, and information security controls.

The change management process serves three functions simultaneously: it is an IT operations quality control (preventing disruptive changes), a GxP regulatory obligation (protecting validated states), and an information security control (preventing unauthorised configuration changes). These three functions are complementary, not competing — a well-executed change management process satisfies all three.

2. Scope

This process applies to all changes to production systems, infrastructure, and services — regardless of the initiating team or the perceived size of the change. The scope includes:

- Application software: new deployments, updates, patches, configuration changes, integration changes
- Infrastructure: server configuration, network changes, storage changes, cloud resource changes, security configuration changes
- Database: schema changes, stored procedure changes, access control changes, configuration parameter changes
- Access control: changes to user access rights, role definitions, MFA policy, and privileged account configurations (via SOP-008 and SOP-009, which initiate changes through this process)
- GxP systems: any change to a system in validated state — including those that would be Standard changes on non-GxP systems — requires a GxP Impact Assessment per Section 6

The following are explicitly outside scope: changes to development and isolated test environments with no connection to production data; content updates to internal wikis or collaboration tools where no system configuration is altered; bug fixes applied by vendors to SaaS platforms as part of their standard release process (these must be tracked via vendor change notification per POL-013, but do not require a Change Request from [Company Name]).

3. Change Categories

All changes are categorised at submission. Category determines the required approval authority, testing requirements, CAB involvement, and — for GxP systems — the validation impact assessment depth. Miscategorisation of a change is a change management process deviation and must be corrected before implementation.

Category	Definition	GxP Applicability	Approval Authority	CAB Required?
Standard	Pre-approved, low-risk, repeatable changes with a defined procedure and known outcome. Examples: approved OS security patches within defined parameters; password resets; standard user access provisioning (via SOP-008); certificate renewals within expiry window.	Standard category does not apply to Track A (fully validated) GxP systems. Track B/C/D GxP systems: Standard changes require a Validation Impact Assessment confirming no GxP data flow impact before proceeding.	Pre-approved by CAB (procedure approved, not individual changes). Implementer confirms suitability of procedure for specific change.	No — procedure was pre-approved. Implementer records execution.
Normal	Changes that require individual assessment, planning, and approval. The default category for any change that is not Standard or Emergency. Examples: application upgrades, new integrations, infrastructure changes, configuration changes outside Standard procedures, access policy changes.	All changes to GxP systems not meeting Standard criteria. Full Validation Impact Assessment required. GxP-impacting changes require Compliance / QA co-approval.	Information Security Manager for non-GxP. Information Security Manager + Compliance / QA Director for GxP-impacting changes. CAB review for changes to Tier 1 or affecting multiple systems.	Yes — for Tier 1 systems and multi-system or high-risk changes. Information Security Manager may approve Normal changes to Tier 2/3/4 without full CAB.
Emergency	Changes that must be implemented immediately to restore service, address a Critical security vulnerability, or prevent imminent patient	Emergency changes to GxP systems require verbal Compliance / QA Director authorisation	CISO (security emergency) or CIO (operational emergency) verbal	Retrospective CAB review within 5

Category	Definition	GxP Applicability	Approval Authority	CAB Required?
	safety or data integrity risk. Emergency changes bypass the standard approval timeline but not the approval authority.	before implementation. Retrospective documentation within 24 hours. Retrospective validation impact assessment and protocol execution as required within 10 business days.	authorisation. Compliance / QA Director for GxP systems. Full documentation within 24 hours.	busines s days.

IMPORTANT: The Minor Change category used in some ITSM frameworks is explicitly excluded from this process for all Track A (fully validated) GxP systems per POL-007. There are no minor changes to a Track A GxP system — all changes require formal assessment regardless of perceived scope.

4. Change Advisory Board (CAB)

The Change Advisory Board is the governance body that reviews and approves Normal changes to Tier 1 systems and high-risk or multi-system changes. The CAB meets weekly under standard operations; an Emergency CAB can be convened within 4 hours if required.

CAB Role	Member	Responsibility
CAB Chair	Information Security Manager	Convenes and chairs CAB. Final approval authority at CAB level for non-GxP changes. Signs Change Advisory Board record.
IT Representative	Data Custodian (IT)	Assesses technical feasibility, implementation risk, and back-out capability. Confirms infrastructure readiness.
GxP Representative	Compliance / QA (for GxP changes only)	Reviews Validation Impact Assessment. Co-approves changes with GxP impact. Assesses whether validated state is affected.
Security Representative	Information Security	Assesses security implications. Confirms security controls are maintained post-change.
Business Representative	System Owner (for affected system)	Confirms business necessity, scheduling acceptability, and user communication requirements.
Service Management	Service Desk Lead	Assesses support readiness, user communication, and scheduling conflicts with other changes.

Changes are added to the CAB agenda at least 5 business days before the proposed implementation date (2 business days for Tier 2 Normal changes). Changes submitted after the agenda deadline are carried to the following week unless escalated to CAB Chair as urgent.

5. Normal Change Lifecycle

Step 01	**Change Request Submission** The Change Requester (any authorised staff member) submits a Change Request (CR) via the ITSM platform. A CR that does not include all mandatory fields is returned to the requester without assessment. Mandatory CR fields: — Change title and description (specific — not 'server update') — Affected system(s) and their POL-005 tier and regulatory flags — Change category (Standard / Normal / Emergency) with rationale — Business justification — Technical implementation plan (step-by-step) — Testing plan — Back-out plan (mandatory — 're-install' is not a back-out plan) — Proposed implementation window — Risk assessment: what could go wrong, what is the impact, how is it mitigated — GxP Impact Assessment (if system has GxP flag — see Section 6) — Change freeze check (Section 8) CR ID assigned automatically by ITSM platform on submission.	Responsible **Change Requester**
Step 02	**Initial Assessment and Categorisation** Information Security Manager reviews the CR within 2 business days of submission: 1. Confirms or corrects the change category. If recategorised, requester notified with rationale. 2. Assesses completeness of the CR. Incomplete CRs are returned to the requester. 3. Identifies affected parties for notification. 4. For GxP-flagged systems: confirms Validation Impact Assessment is present and routes to Compliance / QA for review. 5. Determines whether CAB review is required (Tier 1 system, multi-system impact, or high-risk change). 6. Schedules change for CAB agenda or approves without CAB where within authority. Target: initial assessment completed within 2 business days of submission.	Responsible **Information Security Manager**
Step 03	**GxP and Security Review** Parallel reviews conducted before CAB or final approval: Compliance / QA review (GxP systems only): — Reviews Validation Impact Assessment (Section 6) — Determines re-qualification scope: none, partial, or full — For changes requiring re-qualification: confirms re-qualification plan is included in CR and test protocols are drafted — For changes with no GxP impact: issues GxP No Impact Confirmation filed in CR Information Security review (all Tier 1/2 changes): — Security risk assessment of the proposed change — Confirms no access control or audit trail implications outside the stated scope — Confirms back-out plan is technically sound — Flags any vulnerability management implications	Responsible **Compliance / QA / Information Security**

	(e.g., patch introduces a new dependency)	
Step 04	**CAB Review and Approval** For changes requiring CAB review: 1. Change Requester presents the CR to CAB (5-minute summary; CAB has pre-read the CR) 2. CAB members raise questions and identify any gaps in the implementation or back-out plan 3. CAB decision options: — Approved: CR approved as submitted. Proceed to implementation window. — Approved with conditions: CR approved with specific conditions (e.g., additional testing, enhanced monitoring post-implementation). Conditions are binding. — Deferred: more information or further preparation required. Resubmit at next CAB. — Rejected: change is not approved. Requester notified with reasons. 4. CAB decision and all conditions recorded in the ITSM platform. 5. CAB Chair signs the Change Advisory Board record.	Responsible **CAB / Information Security Manager**
Step 05	**Implementation** Changes are implemented only within the approved implementation window and by the named implementer(s). During implementation: — Implementation follows the step-by-step plan in the CR — deviations from the plan must be assessed against the back-out criteria in real time — All steps are timestamped and recorded in the ITSM platform as the change is executed — For GxP systems: all changes are recorded in the system audit trail; implementer confirms audit trail is recording before starting — For Tier 1 systems: a second person (change peer reviewer) monitors implementation in real time Back-out triggers: — Any step in the implementation plan fails and cannot be resolved within the change window — Service impact detected that was not anticipated in the risk assessment — For GxP systems: any anomaly that may affect validated state If back-out is executed: back-out steps documented in ITSM. Change closed as Failed. Root cause assessed before re-submission.	Responsible **Change Implementer / Change Peer Reviewer (Tier 1)**
Step 06	**Post-Implementation Review (PIR)** All Normal changes to Tier 1 systems and all GxP-impacting changes require a Post-Implementation Review within 5 business days of implementation. PIR confirms: — Change implemented as planned: yes/no. If no, document deviations. — System performing as expected post-change: yes/no — For GxP changes requiring re-qualification: re-qualification executed and approved by Compliance / QA — Audit trail confirmed functioning post-change (GxP and Tier 1) — Any monitoring alerts triggered post-change reviewed and resolved — VMF updated with change record (GxP systems) — Any new risks or issues identified escalated to IS Risk Register (POL-010) PIR completed and signed off in ITSM platform. Change record closed. Normal changes to Tier 2/3/4 non-GxP systems: PIR is recommended but not mandatory unless the change resulted in service disruption or other issues.	Responsible **Change Requester / Information Security Manager**

6. Emergency Change Process

Emergency changes are implemented outside the standard approval timeline because service disruption, patient safety risk, or critical security vulnerability requires immediate action. The reduced approval timeline does not reduce the approval authority requirement — it changes the medium (verbal) and timing (before implementation) but not the substance (CISO or CIO must authorise).

Step 01	**Emergency Declaration** The Change Requester contacts the CISO (security emergency) or CIO (operational emergency) directly — not via ITSM ticket — and provides: — Nature of the emergency and systems affected — Proposed change and implementation approach — Assessment of the risk of not implementing immediately — Back-out capability For GxP systems: Compliance / QA Director must also be contacted before implementation. If Compliance / QA Director is unreachable, the on-call Compliance contact is notified.	Responsible **Change Requester / CISO or CIO**
Step 02	**Verbal Authorisation and Implementation** On verbal authorisation from CISO or CIO (and Compliance / QA Director for GxP systems): 1. Change Requester records: time of authorisation, authorising individual, nature of authorisation, and any conditions imposed 2. Implementation proceeds immediately per the verbal authorisation scope — implementer does not deviate from the authorised scope without a further verbal authorisation 3. For GxP systems: Compliance / QA Director confirms verbal that the change is understood and authorised before the first production change is made 4. All implementation steps timestamped and recorded — even during emergency implementation	Responsible **Change Implementer / CISO or CIO / Compliance QA (GxP)**
Step 03	**Documentation within 24 Hours** A full Change Request is submitted in the ITSM platform within 24 hours of implementation completion, containing: — Emergency declaration rationale — Authorisation details (who, when, verbal or written) — Implementation steps actually executed (not the planned steps — what was actually done) — Post-implementation status — For GxP: Validation Impact Assessment and assessment of whether retrospective re-qualification is required — Back-out status (was back-out required? if yes, what was done?) Failure to document within 24 hours is a change management process deviation and must be reported to Information Security Manager.	Responsible **Change Requester**
Step 04	**Retrospective CAB Review** All Emergency changes are reviewed by CAB within 5 business days of implementation. Retrospective CAB review: — Confirms the emergency was genuine (not a process bypass) — Confirms the change was implemented within the authorised scope — Assesses whether the	Responsible **CAB / Information Security Manager**

emergency reveals a systemic issue requiring a Problem Record (per SOP-015) — For GxP: confirms Validation Impact Assessment is complete and retrospective re-qualification plan is in place if required — Records CAB conclusion in ITSM platform CAB may accept, accept with conditions, or escalate to Information Security Manager if the emergency change raises governance concerns.

7. GxP Validation Impact Assessment

All changes to systems with a GxP flag — regardless of change category — require a Validation Impact Assessment (VIA) before the change is implemented. The VIA is produced by the Validation Lead (or Compliance / QA where no dedicated Validation Lead is assigned) and reviewed by Compliance / QA.

VIA Field	Content Required
Change Summary	Brief description of the change as it relates to the GxP system
GxP Data Flows Affected	List of GxP data flows that interact with the changed component. If none: explicitly state 'No GxP data flows affected' with rationale.
Validated State Impact	Assessment of whether the change alters the validated configuration of the system. Options: No Impact / Partial Impact (configuration within validated boundary) / Full Impact (affects validated state — re-qualification required)
Re-qualification Scope	If impact is Partial or Full: the specific IQ, OQ, and/or PQ sections that must be re-executed, with rationale. If No Impact: 'N/A'.
Audit Trail Assessment	Does the change affect audit trail behaviour, configuration, or storage? If yes: describe impact and confirm immutability requirement is maintained.
Access Control Assessment	Does the change affect user roles, permissions, or access controls on the GxP system? If yes: describe impact and confirm change is accompanied by SOP-008 access review.
ALCOA+ Assessment	Confirms that after the change, GxP records will continue to be: Attributable (individual user identity), Legible, Contemporaneous (correct timestamp), Original, Accurate, Complete, Consistent, Enduring, Available.
VMF Update Required	Yes / No. If Yes: describe VMF sections to be updated and timeline.
Compliance / QA Decision	Approved: No re-qualification required / Approved: Partial re-qualification per scope above / Approved: Full re-qualification required / Not Approved: change must be redesigned. Compliance / QA signature and date.

IMPORTANT: A VIA that concludes 'No Impact' on a Track A system must include explicit rationale

for each GxP data flow and system function. A blanket 'no impact' with no analysis is not acceptable and will be returned by Compliance / QA for revision.

8. Change Freeze Periods

Change freeze periods are scheduled periods during which Normal and Standard changes to specified systems are prohibited. Emergency changes are permitted during freeze periods but require a higher approval threshold.

Freeze Type	Scope	Duration	Approval for Emergency Changes During Freeze
Financial Close Freeze	All SOX ITGC systems and their Tier 1/2 dependencies	5 business days before and during month-end close; 10 business days before and during year-end close. Finance Director confirms close calendar annually.	CFO + CIO + CISO verbal authorisation required (vs. CIO or CISO alone outside freeze)
GxP Regulatory Inspection Freeze	All GxP systems and their Tier 1/2 dependencies	Announced by Compliance / QA Director: typically 2 weeks before a scheduled regulatory inspection through to inspection closure. May be shorter for unannounced inspections.	Compliance / QA Director + CIO + CISO required (vs. standard Emergency Change approval)
Major Release Freeze	System-specific or enterprise-wide as declared by CIO	Declared per release — typically 48–72 hours before and after a major infrastructure or platform release	CIO + CISO required
Holiday Freeze	Tier 1 and GxP systems	As declared annually by CIO (typically: Christmas/New Year period). Tier 2/3/4 changes at Change Requester discretion with reduced support staff risk noted in CR.	CIO + CISO required

Freeze periods are published in the ITSM change calendar at the start of each year and updated when unplanned freezes are declared. Change Requesters are responsible for checking the change calendar before submitting a CR with a proposed implementation date that falls in or near a freeze period.

9. Standard Change Windows

Standard change windows are the default permitted times for production changes. Changes outside these windows require Change Requester justification and Information Security Manager approval in the CR.

System Tier	Standard Change Window	Blackout Period	Notes
Tier 1	Tuesday and Thursday 22:00–04:00 (local server time)	Monday and Friday: minimise weekend recovery risk. Financial close and inspection freezes per Section 8.	Tier 1 changes require same-day CAB Chair confirmation of window suitability.
Tier 2	Tuesday–Thursday 20:00–06:00	Freeze periods per Section 8.	Peer reviewer required for significant Tier 2 changes.
Tier 3/4	Any time outside business hours (18:00–08:00 local)	Freeze periods where Tier 3/4 is a dependency of a frozen Tier 1/2 system.	
GxP systems	As per system tier above, subject to GxP inspection freeze	GxP inspection freeze per Section 8.	Change window must avoid active batch processing or GxP data capture periods — System Owner confirms.

10. Related Documents

Document ID	Title	Relationship
POL-007	Change Management Policy	Parent policy — this SOP operationalises POL-007
POL-005	System Classification Policy	System tier and regulatory flags determine change category eligibility, CAB requirement, and change window
POL-006	Computer System Validation	All changes to GxP systems in validated state

Document ID	Title	Relationship
	and Qualification Policy	require VIA per this SOP; Track A systems have no Standard change category
POL-008	Access Control Policy	Access changes are initiated via SOP-008 and implemented through this change management process
POL-009	Privileged Access Management Policy	Privileged account changes (including service account creation/modification) require a Change Request under this SOP
POL-010	Information Security Risk Policy	Changes introducing new risk or exposing existing risk are flagged to the IS Risk Register; high-risk changes may require a pre-change risk assessment
POL-011	Business Continuity Policy	DR test scheduling and BC/DR change activities are coordinated through this process; change freeze during BC/DR activation is automatic
POL-012	Incident Response Policy	Incident response remediation changes are Emergency changes under this SOP; post-incident hardening changes are Normal changes
POL-014	Audit Trail and Monitoring Policy	Audit trail configuration changes require dual approval (CISO + DIO) and are Normal changes minimum; any change that could affect audit trail behaviour is flagged in the VIA
POL-015	IT Service Management Policy	Operational incident resolution involving production system changes uses Emergency Change procedure; Known Error workarounds implemented through Normal changes
SOP-006	Computer System Validation Process	VIA requirements in Section 7 of this SOP align with SOP-006 change management section; re-qualification following a change is governed by SOP-006
SOP-008	Access Control Process	User access provisioning, modification, and deprovisioning initiated via SOP-008 are implemented as Standard changes through this SOP
SOP-010	IS Risk Assessment Process	High-risk changes identified by this process are escalated to the IS Risk Register via SOP-010
SOP-012	Security Incident Response Process	Emergency remediation changes during a security incident use Emergency Change procedure; CISO authorises both the incident response action and the change
SOP-015	ITSM and Operational Incident Process	Production fixes during P1/P2 incidents use Emergency Change procedure; Problem Management generates Normal change requests for permanent solutions

Document ID	Title	Relationship
EXC-001	Exception Management Policy and Register	Change management exceptions have a 3-month maximum duration; exceptions enabling uncontrolled changes to GxP systems are non-approvable per EXC-001 Section 5
RACI-001	Roles, Responsibilities and Authorities	Accountability for change management governance

11. Definitions

Term	Definition
Back-out Plan	The documented procedure for reverting a change if it fails or causes unacceptable impact. Must be executable within the change window.
CAB	Change Advisory Board — the governance body that reviews and approves Normal changes to Tier 1 systems and high-risk changes.
Change Freeze	A scheduled or declared period during which Normal and Standard changes to specified systems are prohibited.
Change Request (CR)	The formal record of a proposed change, submitted via the ITSM platform, containing all mandatory fields per Section 5 Step 1.
Change Window	The approved time period during which a change may be implemented.
Emergency Change	A change that must be implemented immediately to restore service, address a Critical security vulnerability, or prevent imminent patient safety or data integrity risk.
GxP Impact Assessment (VIA)	The documented assessment of whether a proposed change affects the validated state of a GxP computer system per Section 7 of this SOP.
Normal Change	A change requiring individual assessment, planning, and approval — the default category for any change not meeting Standard or Emergency criteria.
PIR	Post-Implementation Review — the confirmation that a change was implemented as planned and the system is performing as expected.
Standard Change	A pre-approved, low-risk, repeatable change with a defined procedure. Does not apply to Track A GxP systems.
Validated State	The condition of a GxP computer system that has been validated per SOP-006 and is operating within its validated specification.

— End of Document —

SOP-007 v1.0 DRAFT | [Company Name] | INTERNAL USE